

Privacy Policy

> **Document Version:** 1.0
> **Document Owner:** Acme SaaS Inc.
> **Next Review Date:** 2027-03-16

Effective Date: 2026-03-16
Last Updated: 2026-03-16
Previous Version: [View previous version]([previous-version-url])

Project: acme-saas

Review Notes

What a lawyer should check

- Verify all data collection practices are accurately described
- Confirm legal basis selections for each processing purpose
- Check international transfer safeguards are properly documented
- Ensure CCPA/CPRA sections are complete if California residents are served
- Validate data retention periods against applicable laws
- Confirm DPO contact information is correct

Auto-generated vs. needs human input

Section	Status	Confidence
Third-party services list	Auto-detected from code	High
Data categories	Auto-detected from service types	Medium
Legal basis table	Auto-assigned defaults	Low
Retention periods	Template defaults	Low
Contact information	From config file	High
CCPA rights section	Auto-generated if applicable	Medium

Related Documents

- Cookie Policy (`COOKIE\_POLICY.md`)
- Data Processing Agreement (`DATA\_PROCESSING\_AGREEMENT.md`)
- DSAR Handling Guide (`DSAR\_HANDLING\_GUIDE.md`)
- Sub-Processor List (`SUBPROCESSOR\_LIST.md`)
- Data Subject Categories (`DATA\_SUBJECT\_CATEGORIES.md`)
- Lawful Basis Assessment (`LAWFUL\_BASIS\_ASSESSMENT.md`)
- Record of Processing Activities (`RECORD\_OF\_PROCESSING\_ACTIVITIES.md`)

1. Introduction

This Privacy Policy ("Policy") describes how Acme SaaS Inc. ("we", "us", or "our") collects, uses, discloses, and otherwise processes your personal data when you access or use our services. This Policy applies to all personal data processed in connection with our websites, applications, and related services (collectively, the "Service").

We are committed to protecting your personal data in accordance with the General Data Protection Regulation (EU) 2016/679 ("GDPR"), the California Consumer Privacy Act as amended by the California Privacy Rights Act ("CCPA/CPRA"), and other applicable data protection legislation.

****Data Controller:**** Acme SaaS Inc.
****Contact Email:**** privacy@acme.com

2. Data Protection Officer

Our designated Data Protection Officer (DPO), appointed pursuant to GDPR Art. 37, can be contacted at:
– ****Email:**** dpo@acme.com

3. Information We Collect

In accordance with GDPR Art. 13(1)(e) and Art. 14(1)(d), we collect the following categories of personal data:

Personal Identity Data

Email addresses, names, profile pictures, and account credentials collected through authentication.

****Collected through:**** @supabase/supabase-js

Financial Data

Payment card information, billing addresses, and transaction history processed through payment providers.

****Collected through:**** stripe

Usage & Behavioral Data

Page views, click patterns, session recordings, device information, and IP addresses collected through analytics tools.

****Collected through:**** posthog

AI Interaction Data

User prompts, conversation history, and AI-generated content processed through third-party AI services.

****Collected through:**** openai

Communication Data

Email addresses and email content processed through email service providers.

****Collected through:**** resend

Technical & Diagnostic Data

Error reports, stack traces, performance data, and user context collected through monitoring tools.

****Collected through:**** @sentry/node

How Your Data Flows Through Our Service

The following summarizes how personal data moves through our application:

****Data Collection:****

- User registration/login → email, password hash, session data, user metadata (via @supabase/supabase-js)
- AI-powered feature usage → user prompts, conversation history, generated content (via openai)
- Email subscription/contact forms → email addresses, email content (via resend)
- Payment checkout → payment information, billing address, email, transaction history (via stripe)

****Third-Party Data Sharing:****

- @sentry/node: error data, stack traces, user context, device information, IP address
- openai: user prompts, conversation history, generated content
- posthog: user behavior, session recordings, feature flag usage, device information
- resend: email addresses, email content
- stripe: payment information, billing address, email, transaction history

Data Sensitivity Classification

We classify the personal data we collect according to GDPR sensitivity levels to ensure appropriate protection:

Sensitivity Level	Fields Detected	Protection Standard
Special Category (Art. 9)	2	Explicit consent, DPIA, encryption, DPO oversight
High	6	Encryption, tokenization, access control, audit logging
Medium	5	Encryption in transit, consent, user access rights
Low	21	Encryption in transit, anonymization where possible

For a detailed breakdown of each data field and its classification, see our Data Classification Report.

4. Third-Party Services and Data Recipients

Pursuant to GDPR Art. 13(1)(e), we disclose your personal data to the following categories of recipients and third-party data processors:

- ****@sentry/node**** (Error Monitoring): Processes error data, stack traces, user context, device information, IP address
- ****@supabase/supabase-js**** (Authentication): Processes email, password hash, session data, user metadata
- ****openai**** (AI Service): Processes user prompts, conversation history, generated content
- ****posthog**** (Analytics): Processes user behavior, session recordings, feature flag usage, device information
- ****resend**** (Email Service): Processes email addresses, email content
- ****stripe**** (Payment Processing): Processes payment information, billing address, email, transaction history

Each third-party service provider processes your data under its own privacy policy and data processing agreement. We require all processors to implement appropriate technical and organisational measures in accordance with GDPR Art. 28.

5. Legal Basis for Processing (GDPR Art. 6)

Under the General Data Protection Regulation, we process your personal data based on the following legal grounds:

Purpose	Legal Basis	GDPR Article	Details
Error Monitoring	Legitimate Interest	Art. 6(1)(f)	Protecting our service, detecting errors, and ensuring security
Authentication	Contract	Art. 6(1)(b)	Necessary to fulfill our agreement with you
AI Service	Consent	Art. 6(1)(a)	Only with your opt-in consent; or Contract (Art. 6(1)(b)) if integral to the service
Analytics	Consent	Art. 6(1)(a)	Only with your opt-in consent
Email Service	Legitimate Interest	Art. 6(1)(f)	Communicating service-related information to you
Payment Processing	Contract	Art. 6(1)(b)	Necessary to fulfill our agreement with you

Legitimate Interests Pursued

Where we rely on legitimate interest as a legal basis, we have conducted a balancing test to ensure our interests do not override your fundamental rights and freedoms. Our legitimate interests include:

- ****Error Monitoring:**** Protecting our service, detecting errors, and ensuring security
- ****Email Service:**** Communicating service-related information to you

6. Artificial Intelligence

This application uses AI-powered features provided by third-party services:

- **openai**: user prompts, conversation history, generated content

How We Use AI

- User inputs may be sent to AI service providers for processing
- AI-generated outputs are returned to the user
- We do not use your data to train AI models
- AI service providers may retain data according to their own policies

> **Note:** Review the AI Disclosure document for detailed information about our AI usage as required by the EU AI Act.

7. International Data Transfers

Pursuant to GDPR Art. 13(1)(f), we inform you that your personal data may be transferred to and processed in countries outside the European Economic Area (EEA) that may not provide an equivalent level of data protection. The following services involve such transfers:

- **@sentry/node** (Error Monitoring)
- **openai** (AI Service)
- **posthog** (Analytics)
- **resend** (Email Service)
- **stripe** (Payment Processing)

In accordance with GDPR Chapter V (Arts. 44–49), we ensure that appropriate safeguards are in place for all international transfers, including:

- Transfers to countries with an EU adequacy decision
- Standard Contractual Clauses (SCCs) approved by the European Commission
- EU-US Data Privacy Framework certification (where applicable)

You may request a copy of the applicable safeguards by contacting us at privacy@acme.com.

8. Data Retention

In accordance with the data minimisation principle (GDPR Art. 5(1)(e)), we retain your personal data only for as long as necessary to fulfill the purposes for which it was collected, unless a longer retention period is required or permitted by applicable law.

Data Type	Retention Period
Error Monitoring	Error and performance data retained for up to 90 days
Authentication	Account data retained until you delete your account
AI Service	AI interaction data retained for up to 90 days
Analytics	Analytics data retained for up to 26 months
Email Service	Email communication records retained for up to 3 years
Payment Processing	Transaction records retained for 7 years (tax and legal compliance)

9. Your Rights

Under applicable data protection legislation, you may exercise the following rights with respect to your personal data:

- **Right of Access (Art. 15):** You have the right to obtain confirmation as to whether your personal data is being processed and, where that is the case, to request a copy of the personal data undergoing processing.
- **Right to Rectification (Art. 16):** You have the right to obtain the rectification of inaccurate personal data and, taking into account the purposes of the processing, to have incomplete personal data completed.
- **Right to Erasure (Art. 17):** You have the right to obtain the erasure of your personal data where one of the grounds set out in Art. 17(1) GDPR applies, subject to the exceptions in Art. 17(3).
- **Right to Data Portability (Art. 20):** You have the right to receive your personal data in a structured, commonly used, and machine-readable format, and to transmit that data to another controller without hindrance.
- **Right to Object (Art. 21):** You have the right to object, on grounds relating to your particular situation, to the processing of your personal data based on Art. 6(1)(e) or (f). We shall cease processing unless we demonstrate compelling legitimate grounds.
- **Right to Restriction of Processing (Art. 18):** You have the right to obtain restriction of processing where one of the conditions set out in Art. 18(1) GDPR applies.

For EU/EEA Residents (GDPR)

Pursuant to GDPR Art. 77, you have the right to lodge a complaint with a supervisory authority, in particular in the Member State of your habitual residence, place of work, or place of the alleged infringement.

For California Residents (CCPA/CPRA)

Under the California Consumer Privacy Act and California Privacy Rights Act:

Categories of Personal Information Collected

- Internet or other electronic network activity (device info, error reports, IP address)
- Identifiers (name, email address, account credentials)
- Inferences drawn from personal information (AI-generated profiles and predictions)
- Internet or other electronic network activity (browsing history, interactions with website)
- Identifiers (email address, communication records)
- Financial information (payment card details, billing address, transaction history)

Categories of Sources

We collect personal information from the following categories of sources:

- Automatically (error reports, device information, IP address)
- Directly from you (account registration, login forms)
- Directly from you (inputs to AI-powered features)
- From third parties (AI service providers)
- Automatically (cookies, web beacons, analytics tools)
- Directly from you (email address provided at signup or contact)
- Directly from you (checkout and billing forms)
- From third parties (payment processors)

Business or Commercial Purpose for Collection

We collect and use personal information for the following business or commercial purposes:

- **Error Monitoring:** Debugging: Identifying and repairing errors that impair intended functionality; Security: Detecting security incidents and protecting against malicious or illegal activity
- **Authentication:** Performing services: Providing account creation, authentication, and access control
- **AI Service:** Performing services: Providing AI-powered features and functionality integral to the service
- **Analytics:** Auditing: Counting ad impressions, verifying positioning, and auditing compliance; Short-term transient use: Contextualizing and customizing content shown to you
- **Email Service:** Performing services: Sending transactional and service-related communications
- **Payment Processing:** Performing services: Processing transactions, billing, and fulfilling orders

Your CCPA Rights

- Right to Know
- Right to Correct (CPRA Section 1798.106)
- Right to Delete
- Right to Opt-Out of Sale/Sharing
- Right to Limit Use of Sensitive Personal Information
- Right to Non-Discrimination

Do Not Sell or Share My Personal Information

We do not sell your personal information. We share personal information with analytics providers for cross-context behavioral advertising. You may opt out by contacting us at privacy@acme.com or using our opt-out mechanism.

How to Submit a Request

You may submit a request to exercise your CCPA rights through the following methods:

- **Email:** privacy@acme.com
- **Toll-Free Telephone Number:** [1-800-XXX-XXXX] *(update with your toll-free number)*

We will respond to verifiable consumer requests within 45 days.

Authorized Agent

You may designate an authorized agent to make requests on your behalf.

For UK Residents (UK GDPR)

- Supervisory authority: Information Commissioner's Office (ICO)
- International transfers: UK International Data Transfer Agreement (IDTA)

10. Right to Withdraw Consent

Pursuant to GDPR Art. 7(3), where we process your personal data based on your consent (Art. 6(1)(a) or Art. 9(2)(a)), you have the right to withdraw that consent at any time. The withdrawal of consent shall not affect the lawfulness of processing based on consent before its withdrawal.

You can withdraw your consent by:

- Adjusting your preferences in your account settings
- Contacting us at privacy@acme.com

Upon withdrawal, we will cease the relevant processing activities, though some data already collected may be retained where we have another lawful basis for doing so.

11. Automated Decision-Making (Art. 22)

Pursuant to GDPR Art. 13(2)(f), this application uses automated processing, including AI-powered features, as described in the Artificial Intelligence section above.

Meaningful Information About the Logic Involved

Our automated processing uses AI models provided by third-party services (openai). These models analyse the inputs you provide and generate outputs based on statistical patterns learned during training. The processing involves:

- Receiving your input data (text, queries, or other content you submit)
- Processing it through the AI model to generate a response or result
- Returning the AI-generated output to you

Significance and Envisaged Consequences

The use of automated processing may affect you in the following ways:

- AI-generated outputs may influence decisions or actions you take based on them
- The quality and accuracy of outputs depend on the inputs provided and the limitations of the AI model

- Automated processing is not used to make decisions that produce legal effects or similarly significantly affect you without human oversight

Your Rights Regarding Automated Decisions

You have the right not to be subject to decisions based solely on automated processing, including profiling, that produce legal or similarly significant effects concerning you. You may:

- Request human intervention in any automated decision
- Express your point of view regarding automated decisions
- Contest any automated decision that affects you

To exercise these rights, contact us at privacy@acme.com.

12. Necessity of Data Provision (Art. 13(2)(e))

Pursuant to GDPR Art. 13(2)(e), we inform you whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, and the possible consequences of failure to provide such data.

- ****Required data (contractual necessity):**** Data necessary for account creation, authentication, and core service functionality. The provision of this data is a requirement necessary to enter into and perform our contract with you. Failure to provide this data will result in our inability to provide you with the Service.
- ****Optional data (consent-based):**** Data collected for analytics, personalisation, and service improvement. The provision of this data is voluntary and not a contractual requirement. You may decline to provide this data without any impact on your ability to use the core Service.

13. How We Protect Your Data

We implement appropriate technical and organizational measures to protect your personal data against unauthorized access, alteration, disclosure, or destruction.

Encryption

- All data transmitted between your browser and our servers is encrypted using TLS 1.2 or higher
- Sensitive data (such as payment information and credentials) is encrypted at rest using industry-standard encryption algorithms
- Encryption keys are managed through secure key management practices with regular rotation

Access Controls

- Access to personal data is restricted to authorized personnel on a need-to-know basis
- We implement role-based access control (RBAC) to limit data access by job function
- Multi-factor authentication is required for administrative access to systems containing personal data
- Access permissions are reviewed regularly and revoked promptly when no longer needed

Monitoring and Incident Detection

- We use error tracking and performance monitoring (@sentry/node) to detect anomalies and potential security incidents
- Automated alerts are configured for suspicious activity and system errors
- Security events are logged and reviewed to identify potential threats

Security Assessments

- Regular security reviews and vulnerability assessments are conducted
- Third-party services are evaluated for security before integration
- We maintain an incident response plan for handling data breaches (see `INCIDENT\_RESPONSE\_PLAN.md`)

14. Changes to This Policy

We may revise this Policy from time to time to reflect changes in our data processing practices, applicable law, or regulatory guidance. Where we make material changes, we will notify you by reasonable means, such as a prominent notice on the Service or by email to the address associated with your account, at least thirty (30) days prior to the changes taking effect.

We will not reduce your rights under this Policy without your explicit consent. Each version of this Policy will be identified by its effective date, and we will maintain an archive of prior versions available upon request.

Your continued use of the Service after the effective date of any revised Policy constitutes your acceptance of the revised terms. If you do not agree with the revised Policy, you must discontinue use of the Service.

15. Contact

If you have questions about this Policy or wish to exercise your data protection rights, please contact us at:

- **Email:** privacy@acme.com
- **Data Protection Officer:** dpo@acme.com

This Policy was generated by [Codepliant](https://github.com/codepliant/codepliant) based on automated code analysis. This document is provided as a template and does not constitute legal advice. You should have this Policy reviewed by qualified legal counsel before publication.